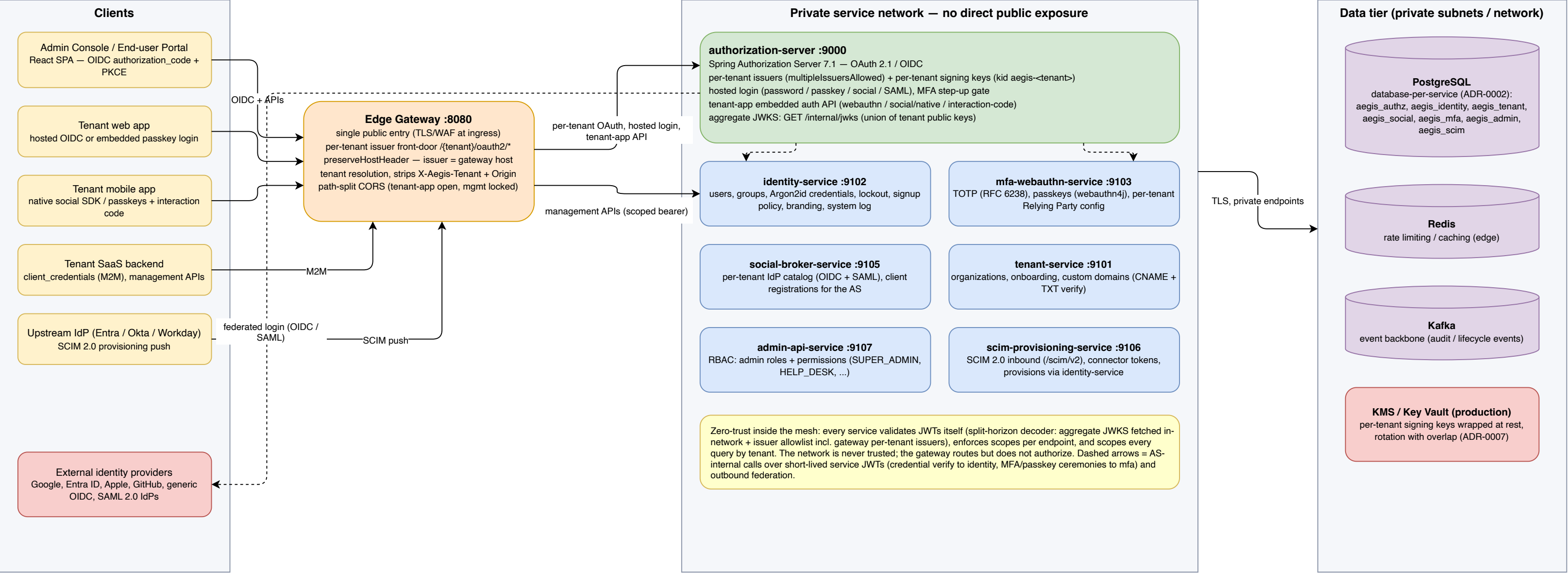


Aegis IAM Platform — Application Architecture (multi-tenant, zero-trust)



Zero-trust posture (all environments)

1. One public front door: only the gateway (and static console) are exposed; services and databases have no public endpoints. 2. Identity over network: every request carries a JWT; every service validates signature + issuer allowlist + scope itself — no implicit trust between services. 3. Per-tenant cryptography: each tenant has its own issuer and signing key; a token for tenant A cannot be forged for tenant B. 4. Least privilege: scoped clients, RBAC admin roles, database-per-service, write-only secrets. 5. Anti-abuse: PKCE mandatory, no ROPC/implicit, Argon2id + lockout, anti-enumeration responses, JIT-link only on verified email, CSP/security headers on hosted pages.

Issuers: per tenant, through the gateway — `https://<gateway>/tenant/` (discovery, authorize, token, JWKS, userinfo). Tokens are signed with the tenant key; resource servers verify via the in-network aggregate JWKS.